



Privacy Impact Assessment

And records of processing

Prepared by – **iorta TechNXT**

Version – **1.0**

Date – **03 October 2026**

TABLE OF CONTENTS

1. Document Control.....	3
2. Acronyms.....	3
3. About these templates.....	4
3.1 Purpose.....	4
3.2 How to use.....	4
3.3 Sources.....	5
4. Part A: Privacy impact assessment.....	6
4.1 Identification.....	6
4.2 Description of the processing.....	6
4.3 Data flow.....	7
4.4 Privacy principles.....	7
4.5 Risk assessment.....	8
4.6 Recommendations and action plan.....	9
4.7 Sign-off of the assessment.....	9
5. Part B: Records of processing activities.....	10
5.1 Controller and processor.....	10
5.2 Processing activities.....	10
5.3 Transfers outside the Philippines.....	12
5.4 Security measures (summary).....	12
5.5 Review log.....	12
6. Document Sign-Off.....	13

1. Document Control

Date	Version	Author & Business Unit Info	Reviewed By & Business Unit Info	Approved By & Business Unit Info	Change History
03 October 2026	1.0	iorta TechNXT	Broker's Data Protection Officer (to be completed)	To be completed by the broker	Template pre-filled from the BrokerVerse data dictionary and configuration; completed and owned by the broker

2. Acronyms

Acronym / Symbol	Definition / Meaning
DPA	Data Privacy Act of 2012 (RA 10173)
IRR	Implementing Rules and Regulations of the DPA
NPC	National Privacy Commission
DPO	Data protection officer
PIC	Personal information controller
PIP	Personal information processor
PIA	Privacy impact assessment
ROPA	Records of processing activities
DSR	Data subject request
KYC	Know your customer
TIN	Taxpayer identification number
BIR	Bureau of Internal Revenue
IC	Insurance Commission
AMLA	Anti-Money Laundering Act
OOTB	Out of the box

3. About these templates

3.1 Purpose

The broker is the personal information controller (PIC) for the personal data held in iNXT BrokerVerse OOTB; iorta TechNXT acts as personal information processor (PIP) when it hosts, supports or accesses the system. Under the Data Privacy Act of 2012, its IRR and the issuances of the NPC, the broker documents its processing and assesses the privacy risks of a new system before it goes live. This document gives the broker's DPO two working templates for BrokerVerse:

- a privacy impact assessment (PIA) of the BrokerVerse implementation, following the structure of the NPC guidelines on privacy impact assessments (NPC Advisory 2017-03);
- records of processing activities (ROPA) for the processing done in BrokerVerse, as part of the organisational security measures of the IRR.

Both are pre-filled with what BrokerVerse holds and does, taken from the data dictionary, the configuration and the code of the release. The broker completes the parts in [square brackets], removes processing it does not use, adds its own purposes and legal bases, and approves the result.

This document is not legal advice. The DPO confirms the legal bases, the retention periods and the NPC issuances in force at the date of the assessment, including the rules on registration (NPC Circular 2022-04) and on breach management (NPC Circular 16-03 or its replacement).

3.2 How to use

1. Hold a PIA workshop in the discovery phase with the DPO, the process owners (sales, placement, policy, claims, accounting), the broker's IT head and the iorta TechNXT project manager.
2. Walk through the records of processing (chapter 6) line by line; confirm or change each pre-filled line.
3. Rate the risks in chapter 5 with the scale below and agree the controls and owners.

4. Record the decisions taken in configuration (two-step verification roles, retention years, notice version, hosting location) in the configuration workbook.
5. The DPO signs the PIA before go-live; review it at least once a year and whenever the processing changes (new line of business, new hosting location, new integration).

3.3 Sources

Source	Used for
BrokerVerse Data Dictionary (chapter on personal data and retention)	Tables and columns that hold personal, sensitive and credential data
Architecture, Infrastructure, Security and Data Privacy	Security measures, hosting options, cross-border transfer
Philippine Regulatory Compliance Matrix	Data Privacy Act chapter
Data Processing Agreement	Roles, sub-processors, breach notice, return and deletion
User Manual, chapter on data privacy	Consent, data subject requests, export and anonymisation

4. Part A: Privacy impact assessment

4.1 Identification

Field	Entry
Organisation (PIC)	[Broker legal name], [address]
DPO	[name, contact]
System assessed	iNXT BrokerVerse OOTB release [1.0], insurance broking and broker accounting
Processor	iorta TechNXT Corp. (hosting and support) under the Data Processing Agreement dated [date]
Hosting location	[AWS Singapore / Azure Singapore / Philippine partner [name, city] / broker's own data centre]
Assessment team	[names and functions]
Date of assessment	[date]
Next review	[date, at most 12 months later]

4.2 Description of the processing

BrokerVerse supports the broker's business from the first contact with a prospect to the renewal of the policy, and the broker's accounting. Personal data enters the system when staff record a prospect, prepare a quotation, issue a policy, register a claim, record a payment or set up a referrer, and through uploads of go-live data from the old system. It leaves the system to insurers and reinsurers (requests for quotation, placement slips, loss advices, bordereaux, remittance statements), to clients (quotations, policy schedules, official receipts, invoices, reminders by e-mail), to payment gateways (payment links) and to the BIR (Form 2307 and alphalists prepared by the broker).

Item	BrokerVerse OOTB
Data subjects	Prospects, clients (insured persons and the contact persons of insured companies), drivers and third parties in claims, claimants and payees, referrers and sub-agents, staff users
Volume	[number of clients, policies a year, claims a year, users]
Personal data	Names, contact details, addresses, birth date, gender, vehicle details, property locations, payment references, bank details of referrers, sign-in history of users
Sensitive personal information	TIN, government ID type, number and image (PhilSys ID, UMID, passport, driver's licence and others in policy.kyc_id_types), birth date, injury and health details in claims where captured
Credentials	Password hashes, encrypted two-step secrets, one-time links and tokens
Users with access	Seven roles: System Administrator, Sales & Marketing, Processing Team, Operations, Claims, Accounting, Accounting Manager; permissions checked by the server on every action
Processor access	iorta TechNXT support (L2, L3) for incidents and changes, under the Data Processing Agreement; [location of the support team]
Retention in the system	Business and financial records kept; personal data of a client or prospect may be anonymised privacy.retention_years (10) years after the last policy expiry; operational logs deleted after their retention days

4.3 Data flow

Stage	How the data enters or leaves	Controls in BrokerVerse
Collection	Typed on the Prospects, Quotations, Policy, Claims and masters screens; uploaded from the go-live templates; client approval of a quotation through a signed link	Required fields limited by configuration (policy.kyc_required_fields for motor); upload type checked against file content; signed links that expire
Use	Pricing, placement, issue, servicing, claims, billing, remittance, commission, accounting, reports	Role permissions; maker-checker and authority limits; audit trail with before and after values
Disclosure	E-mails through the outbox (with PDF attachments for receipts, invoices, policy schedules and debit notes); PDF slips and statements; payment links to PayMongo or Dragonpay; CSV and Excel exports	Outbox with recipients and attachments listed; master switch notification.email_enabled; exports limited by permission; card data entered only on the gateway's page
Storage	PostgreSQL database and file store at the hosting location; backups	Storage encryption of database, files and backups (hosted options); TLS in transit; two-step secrets encrypted in the application
Retention and disposal	Housekeeping job; anonymisation from a data subject request	housekeeping.* days; privacy.retention_years; anonymisation refused while records must be kept

4.4 Privacy principles

Principle	How it is met	Gap or action for the broker
Transparency	Privacy notice of the broker; acknowledgement recorded as the Processing consent with the notice version (privacy.notice_version)	[Publish or update the privacy notice; set the notice version]
Legitimate purpose	Purposes in the records of processing (chapter 6); marketing only with the Marketing consent	[Confirm the purposes; brief the sales team]
Proportionality	KYC data required for motor only by default; optional fields can be left empty	[Decide which optional fields are used]
Data quality	Corrections on the Clients and Prospects screens; Personal Details Change endorsement for issued policies; audit trail	[]
Retention	Records kept for the insurance, tax and AMLA periods; anonymisation after privacy.retention_years	[Approve the retention schedule; set the years]
Security	Security chapters of the Architecture, Infrastructure, Security and Data Privacy document; Annex 2 of the Data Processing Agreement	[Set two-step verification roles; review access twice a year]
Data subject rights	Master > Data Privacy > Data Subject Requests: due date 15 calendar days (privacy.request_due_days), export as JSON or Excel, anonymisation, consent withdrawal	[Confirm the response period; switch on the overdue request job]
Accountability	DPO; Data Processing Agreement with iorta TechNXT; sub-processors listed in its Annex 3	[Register with the NPC where required]

4.5 Risk assessment

Rate each risk on likelihood (1 Unlikely, 2 Possible, 3 Likely, 4 Almost certain) and impact (1 Negligible, 2 Limited, 3 Significant, 4 Maximum) for the data subjects. Risk = likelihood x impact: 1 to 3 Low, 4 to 8 Medium, 9 to 16 High. The ratings below are blank on purpose; the assessment team sets them.

No.	Risk to data subjects	Existing controls in BrokerVerse	Likelihood	Impact	Rating	Further action and owner
1	Unauthorised access by a staff user beyond the job	Seven roles, deny by default; record scope for scoped roles; Access Reviews; dormant accounts deactivated after 90 days	[]	[]	[]	[]
2	Account takeover through a stolen password	Password policy, lockout after 5 failures, two-step verification per role, idle sign-out after 30 minutes	[]	[]	[]	[Set security.require_2fa_roles]
3	E-mail with personal data or attachments sent to the wrong address	Recipient defaults to the client's e-mail; outbox shows recipients and attachments; retry only on failure	[]	[]	[]	[Procedure for checking addresses]
4	Excess data shared with insurers and reinsurers	Slips and bordereaux carry the data the placement or claim needs; Sharing consent recorded	[]	[]	[]	[]
5	Exports (Excel, CSV, PDF) stored on laptops	Exports limited by permission; audit of report runs	[]	[]	[]	[Device and storage policy]
6	Data kept longer than needed	Anonymisation after the retention years; housekeeping of logs	[]	[]	[]	[Annual anonymisation review]
7	Cross-border transfer (hosting in Singapore)	Provider certifications; encryption; Data Processing Agreement	[]	[]	[]	[Record the transfer in the notice and here]
8	Processor staff access to production data	Named staff, multi-factor sign-in, logged access (recommended hosting design)	[]	[]	[]	[Confirm the access list with iorta TechNXT]
9	Personal data in the audit trail and in uploaded documents after anonymisation	Anonymisation clears the party's fields; the audit trail keeps earlier values	[]	[]	[]	[Decide the audit trail retention]
10	Breach not detected or not notified in time	Alarms on failed sign-ins and token reuse (hosted); processor notice within the period of the Data	[]	[]	[]	[Breach response team and register]

No.	Risk to data subjects	Existing controls in BrokerVerse	Likelihood	Impact	Rating	Further action and owner
		Processing Agreement				
11	Client personal identifiers readable by a database administrator	No field-level encryption in this release; storage encryption and restricted database access	[]	[]	[]	[Accept or require a change request]
12	[Other risk found in the workshop]	[]	[]	[]	[]	[]

4.6 Recommendations and action plan

No.	Action	Owner	Due	Status
1	Publish the privacy notice and set <code>privacy.notice_version</code>	[DPO]	Before go-live	[]
2	Record the Processing consent for clients at onboarding; Marketing consent before campaigns	[Operations head]	From go-live	[]
3	Set two-step verification at least for System Administrator, Accounting and Accounting Manager	[System Administrator]	Before go-live	[]
4	Switch on the <code>privacy-requests-due</code> job (Master > Schedules) and give read:privacy to the privacy team	[System Administrator]	Before go-live	[]
5	Confirm <code>privacy.request_due_days</code> and <code>privacy.retention_years</code>	[DPO]	Configuration phase	[]
6	[]	[]	[]	[]

4.7 Sign-off of the assessment

Role	Name	Decision	Date
Data Protection Officer	[]	[Approved / Approved with actions / Not approved]	[]
Process owner	[]	[]	[]
Head of IT	[]	[]	[]
Sponsor	[]	[]	[]

5. Part B: Records of processing activities

5.1 Controller and processor

Field	Entry
Controller	[Broker legal name], [address], [NPC registration number, if registered]
DPO	[name, e-mail, telephone]
Processor	iorta TechNXT Corp., hosting and support of iNXT BrokerVerse OOTB, Data Processing Agreement dated [date]
Sub-processors	As in Annex 3 of the Data Processing Agreement: [hosting provider and region]; [e-mail provider, if any]; [support tooling]
Systems	iNXT BrokerVerse OOTB; [other systems]

5.2 Processing activities

One row per activity. The columns follow what the IRR expects the records to show: purpose, data subjects, categories of data, recipients, transfers, retention and security. The legal basis is the DPO's decision; the entries are suggestions.

No.	Activity and purpose	Data subjects	Personal data (sensitive in bold)	Where in BrokerVerse	Legal basis (to confirm)	Recipients	Retention
1	Prospecting and quotation: record prospects, price and send quotations	Prospects, contact persons	Name, company, e-mail, phone, address, gender, birth date, TIN (corporate)	leads, quotes, package_quotes; Operations > Sales & Marketing	Steps at the request of the data subject before a contract; consent for marketing	Insurers (quotation submitted); client by e-mail	[3 years if not converted, then anonymise or delete]
2	Placement with insurers	Clients, insured persons	Insured name, risk details, vehicle details, property location	broker_slips, placements; Request for Quotation, Placement Slips	Contract with the data subject	Insurers and co-insurers	[Life of the policy plus 10 years]
3	Policy issue and servicing, including KYC	Clients, insured persons	Name, contact details, address, vehicle (plate, chassis, motor number), government ID type, number and image, TIN, birth date	clients, policies, endorsements, documents; Operations > Policy, Clients	Contract; legal obligation (KYC, AMLA where it applies)	Insurers; client (policy schedule by e-mail)	[Life of the policy plus 10 years; privacy.retention_years]
4	Claims handling	Clients, drivers, third parties, claimants, payees	Loss details and address, driver and third-party details, injury details where	claims, claim documents; Operations > Claims	Contract; establishment of legal claims	Insurers, adjusters, reinsurers (recoveries)	[Closure of the claim plus 10 years]

No.	Activity and purpose	Data subjects	Personal data (sensitive in bold)	Where in BrokerVerse	Legal basis (to confirm)	Recipients	Retention
			captured , payee and bank details, claim documents and photos				
5	Billing, receipts, collections and online payments	Clients, payers	Name, customer code, amounts, payment references, payer name, e-mail and mobile on payment links	receivables, receipts, policy_payments, payment_links, payment_events; Accounts	Contract; legal obligation (books of accounts)	Client (receipts and invoices by e-mail); payment gateways (PayMongo, Dragonpay)	[10 years after the financial year end]
6	Remittance and accounting with insurers	Clients (as insured)	Insured name on remittance lines, statements and debit notes	remittance_lines, commission_debit_note_lines, insurer_statement_lines	Contract; legal obligation	Insurers	[10 years after the financial year end]
7	Commission to referrers and sub-agents; withholding tax	Referrers, sub-agents	Name, e-mail, phone, bank name and account number, TIN	commission_referrers, disbursement_s, bir_2307_certificates	Contract; legal obligation (withholding tax)	Banks (payment); BIR (Form 2307, QAP filed by the broker)	[10 years after the financial year end]
8	Reinsurance cessions and recoveries	Insured persons	Insured name, sum insured, claim amounts	cessions, reinsurance_recoveries	Contract; legitimate interest	Reinsurers	[Life of the treaty plus 10 years]
9	Renewals and retention campaigns	Clients	Name, contact details, policy and premium	renewals, renewal_notices; Operations > Renewals	Contract (renewal notices); consent for win-back marketing	Client by e-mail	[As activity 3]
10	Consent and data subject requests	Clients, prospects, requesters	Consent per purpose with evidence; requester name and contact; request details and outcome	privacy_consents, data_subject_requests; Master > Data Privacy	Legal obligation (DPA)	Data subject (export)	[Keep as evidence; the DPO sets the period]
11	User administration and security monitoring	Staff users	Name, username, e-mail, phone, employee code, department, designation, reporting line, sign-in history with IP and	users, login_history, audit_log; Master > Generals > User Management, Audit Trail	Legitimate interest (security); contract of employment	iorta TechNXT support (incidents)	Sign-in history 365 days (housekeeping.login_history_days); audit trail kept

No.	Activity and purpose	Data subjects	Personal data (sensitive in bold)	Where in BrokerVerse	Legal basis (to confirm)	Recipients	Retention
12	E-mail delivery	Recipients of e-mails	browser Address, cc, message body and attachments	email_outbox ; Master > E-mail Outbox	As the activity the e-mail belongs to	Broker's SMTP provider	Sent 180 days, failed 730 days (housekeeping.email_outbox_*)
13	[Other activity of the broker]	[]	[]	[]	[]	[]	[]

5.3 Transfers outside the Philippines

Transfer	Country	Safeguard	Recorded in the privacy notice
Hosting of the database, files and backups (options A and B)	Singapore	Data Processing Agreement; provider's data processing terms and certifications; encryption	[yes / no]
Support access by iorta TechNXT staff	[country of the support team]	Data Processing Agreement; named staff; logged access	[yes / no]
[Insurer or reinsurer abroad]	[]	[]	[]

5.4 Security measures (summary)

Type	Measures
Organisational	DPO; privacy notice; Data Processing Agreement with the processor; access reviews twice a year (recommended); training of staff
Physical	Data centre controls of the hosting provider or partner; [broker office measures]
Technical	Named users; password policy and lockout; two-step verification per role; permission check on every action; maker-checker and authority limits; audit trail; HTTPS and TLS; storage encryption of database, files and backups; daily backups with point-in-time recovery; monitoring and alarms (hosted options)

5.5 Review log

Date	Change to the records	By
[date]	First version for go-live	[DPO]

6. Document Sign-Off

Serial Number	Description	Owner	Status
1	The broker's DPO completes, confirms the legal references in force and approves the assessment	Broker's Data Protection Officer	Open

Sign Off Date	Signature	Approved By	Department & Project Role



Insurance technology for the Philippines



10+

COUNTRIES

Global Presence



8

GLOBAL OFFICES

Strategically Located



11+

MARKETS SERVED

Across Continents



100%

COMMITMENT

To Excellence



MALAYSIA



INDIA



PHILIPPINES



THAILAND



VIETNAM



USA



ETHIOPIA



CAMBODIA



HONGKONG



SINGAPORE



Scan More Details